Matrice de risques CID : actifs touchés

Échelle d'impact 0 à 4 (0 = non démontré, jamais « absent ») ; criticité de l'actif 1 à 4. Données : `Matrice-risques-CID.csv`. **Rien n'est affirmé au-delà des artefacts** : annuaire compromis, système industriel touché et nature des données sorties ne sont pas démontrés.

Actif	Criticité	C obs.	I obs.	D obs.	C pot.	I pot.	D pot.
comptabilite-07	2	0	3	0	3	3	1
srv-fichiers-02	3	0	2	0	4	3	2
dc-01	4	3	2	0	4	4	3
Données sorties (contenu inconnu)	4 (si données sensibles)	3	0	0	4	1	0
Compte svc-backup-temp	2	0	2	0	2	3	0

Attention : le même événement (alerte 10, volume sorti de dc-01) fonde l'impact C observé de dc-01 et celui de la ligne « Données sorties » : **ne pas additionner** ces deux notes. Fichier de données : `Matrice-risques-CID.csv`. Une ligne par actif **réellement identifié comme touché** : comptabilite-07, srv-fichiers-02, dc-01, le volume de données sorti, le compte svc-backup-temp. Aucun annuaire compromis, serveur industriel ou exfiltration de données sensibles n'est affirmé : ils ne sont pas démontrés.

Note	Signification (impact)
0	Aucun impact démontré par les artefacts
1	Faible : gêne limitée, récupérable sans conséquence métier
2	Modéré : atteinte d'un composant, remise en état nécessaire
3	Élevé : atteinte sérieuse de données ou d'un service important
4	Critique : atteinte systémique ou de données hautement sensibles

Criticité de l'actif (1 à 4) : fonction (rôle documenté ou déduit), étendue de dépendance, sensibilité probable des données. Elle est **justifiée ligne par ligne** et reste conditionnelle lorsque le rôle est déduit d'un nom d'hôte.

Trois colonnes distinctes : **impact observé** (démontré par un artefact), **impact potentiel** (ce que l'accès observé permettrait), **risque futur** (scénario, non quantifié). Une note observée de 0 signifie « non démontré », jamais « absent ».

comptabilite-07

- **Rôle et source** : poste du service comptabilité, poste d'entrée (mémo)
- **Preuve de l'atteinte** : journal I.1,3,4,12 ; ALERT-001,003,004,012
- **Criticité 2** : poste utilisateur isolé en apparence ; accès à des données financières et à des identifiants d'utilisateurs comptables (rôle déduit)
- **Impact observé** : exécution de code non autorisé (PowerShell masqué), création de tâche planifiée, effacement du journal Security (intégrité des traces) ; aucune lecture de données démontrée
- **Impact potentiel** : accès aux fichiers et identifiants de l'utilisateur ; poursuite de l'intrusion
- **Risque futur** : persistance et rebond si le poste n'est pas reconstruit (tâche, clé Run déclarées)
- **Limites** : logs Security antérieurs possiblement perdus ; données présentes sur le poste inconnues

srv-fichiers-02

- **Rôle et source** : serveur au nom évoquant des fichiers (rôle non documenté)
- **Preuve de l'atteinte** : journal I.6,7,11 ; ALERT-007,008,011
- **Criticité 3** : si c'est un serveur de fichiers : concentration de données de l'entreprise (hypothèse tirée du nom)
- **Impact observé** : session RDP par un compte contradictoire, indice d'injection dans explorer.exe, requête vers le domaine de repli ; aucune lecture de fichiers démontrée
- **Impact potentiel** : lecture et copie de données métier ; chiffrement éventuel
- **Risque futur** : exfiltration ou chiffrement futur si l'accès persiste
- **Limites** : l'origine de l'accès (F4, F7) est INCONNUE ; sensibilité des données INCONNUE

dc-01

- **Rôle et source** : contrôleur de domaine (mémo, nom)
- **Preuve de l'atteinte** : journal I.8,9,10 ; ALERT-005,009,010
- **Criticité 4** : l'annuaire commande l'authentification de tout le SI : sa compromission serait systémique (si le rôle est confirmé)
- **Impact observé** : sortie de 2 469 135 790 octets (contenu INCONNU), accès mémoire à LSASS (lecture), compte créé puis supprimé ; compromission de l'annuaire et vol effectif d'identifiants NON DEMONTRÉS
- **Impact potentiel** : réutilisation d'identifiants, création de comptes privilégiés, déploiement latéral à l'échelle du SI
- **Risque futur** : prise de contrôle du domaine si des identifiants privilégiés ont été extraits
- **Limites** : le contenu de la sortie et l'extraction effective sont INCONNUS ; l'impact C est noté 3 sur la seule base du volume sorti

Données sorties (contenu inconnu)

- **Rôle et source** : volume observé vers 203.0.113.28:8080
- **Preuve de l'atteinte** : journal I.10 ; ALERT-010
- **Criticité 4 (si données sensibles)** : nature des données INCONNUE : criticité potentielle maximale tant que le contenu n'est pas établi
- **Impact observé** : 2,47 Go (2,30 Gio) sortis en clair ; aucun nom de fichier, aucun échantillon
- **Impact potentiel** : divulgation de données internes ou personnelles ; obligations (RGPD) à examiner si des données personnelles sont confirmées
- **Risque futur** : extorsion ou revente possibles (hypothèse, aucune demande observée)
- **Limites** : aucune preuve du contenu ; ne pas écrire « exfiltration de données sensibles » sans preuve

Compte svc-backup-temp

- **Rôle et source** : identité créée puis supprimée (journal I.6,9)
- **Preuve de l'atteinte** : ALERT-007,009
- **Criticité 2** : compte éphémère : usage illégitime possible, privilèges INCONNUS
- **Impact observé** : utilisé en RDP avant sa création selon les journaux (I-03), créé puis supprimé 45 min après
- **Impact potentiel** : accès persistant si les droits étaient élevés
- **Risque futur** : recréation d'un compte similaire
- **Limites** : chronologie contradictoire ; groupes et droits non fournis